



Software Verification and Validation

SUBMITTED TO:

Maam Jawairia Ramzan

SUBMITTED BY:

MUHAMMAD Fahad
FALL-23 080 BSSE (B)

**DEPARTMENT OF SOFTWARE
ENGINEERING**

1. Project Overview

This project focuses on software security validation and compliance evidence compilation using OWASP ZAP by Checkmarx. The objective of the validation process was to identify security vulnerabilities within a demo web application and organize all findings into a structured compliance dossier suitable for audit and review purposes.

The validation activities included:

- Security scanning using OWASP ZAP
- Vulnerability analysis
- Risk identification
- Validation evidence collection
- Risk mitigation planning
- Compliance documentation

The target application scanned during validation was:

<https://demo.owasp-juice.shop/>

2. Summary of Security Validation

Security validation was performed using OWASP ZAP by Checkmarx on the OWASP Juice Shop demo application.

The scan identified several vulnerabilities and security configuration weaknesses related to:

- Content Security Policy (CSP) configuration
- Cross-Domain security misconfiguration
- Server version information disclosure
- Strict-Transport-Security header issues
- Timestamp disclosure

The security validation process included:

- Passive security scanning
- Vulnerability detection
- Validation evidence collection
- Risk assessment
- Compliance documentation

A total of multiple alerts were identified during the scanning process.

3. Risk Register

Risk ID	Risk Description	Source Evidence	Probability	Impact	Risk Level	Mitigation
VR-01	Content Security Policy Header Not Set	ZAP Report	Medium	High	High	Configure CSP header
VR-02	Cross-Domain Misconfiguration	OWASP ZAP Alert	Medium	High	High	Restrict CORS policy
VR-03	Server Version Information Disclosure	Passive Scan	Medium	Medium	Moderate	Hide server version
VR-04	Strict-Transport-Security Header Missing	Validation Log	Medium	Medium	Moderate	Configure HSTS
VR-05	Timestamp Disclosure	Security Evidence	Low	Medium	Low	Remove timestamp exposure

4. Evidence Summary

The following evidence was collected during the validation process:

- OWASP ZAP security scan report
- Alert summary screenshots
- CSP vulnerability screenshots
- Cross-domain misconfiguration evidence
- Validation risk register
- Security configuration findings
- Compliance documentation
- GitHub repository evidence

All validation evidence was organized into a structured compliance dossier for audit review and verification purposes.

5. Mitigation Actions

Vulnerability	Mitigation Action
CSP Header Not Set	Configure Content-Security-Policy security header
Cross-Domain Misconfiguration	Restrict unauthorized CORS origins

Server Version Information Disclosure	Disable unnecessary server information exposure
Strict-Transport-Security Header Not Set	Enable HSTS security configuration
Timestamp Disclosure	Remove unnecessary timestamp information from responses

9. Conclusion

The software security validation process successfully identified multiple security vulnerabilities within the OWASP Juice Shop demo application. All findings were analyzed and converted into structured validation risks with corresponding mitigation recommendations.

The generated compliance dossier provides organized validation evidence suitable for audit review, software verification activities, and compliance documentation.

The project also demonstrates the practical use of OWASP ZAP for vulnerability detection, risk analysis, and security validation reporting.